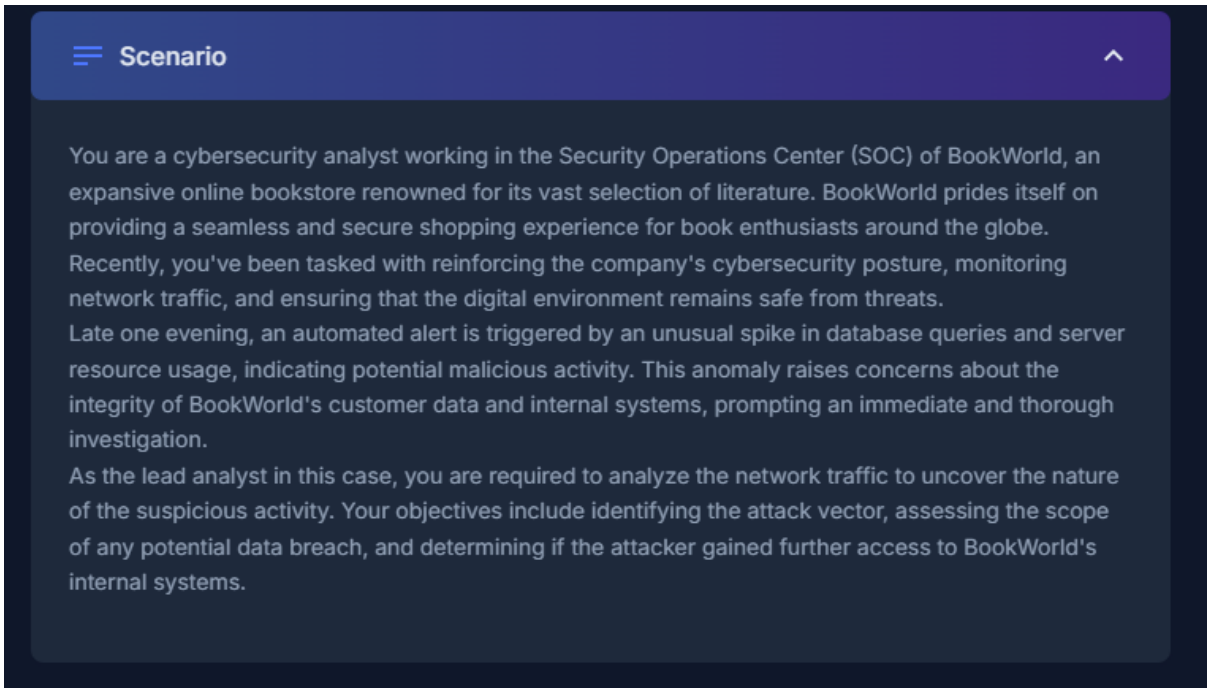
Matt Ball

---

*CYBER DEFENDERS WEB INVESTIGATION LAB*

---




Tools used:

Wireshark

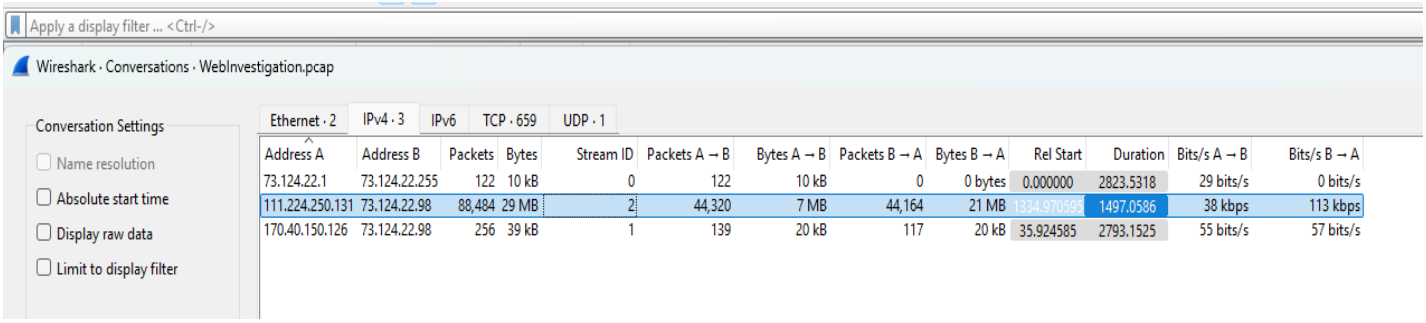
Cyber Chef

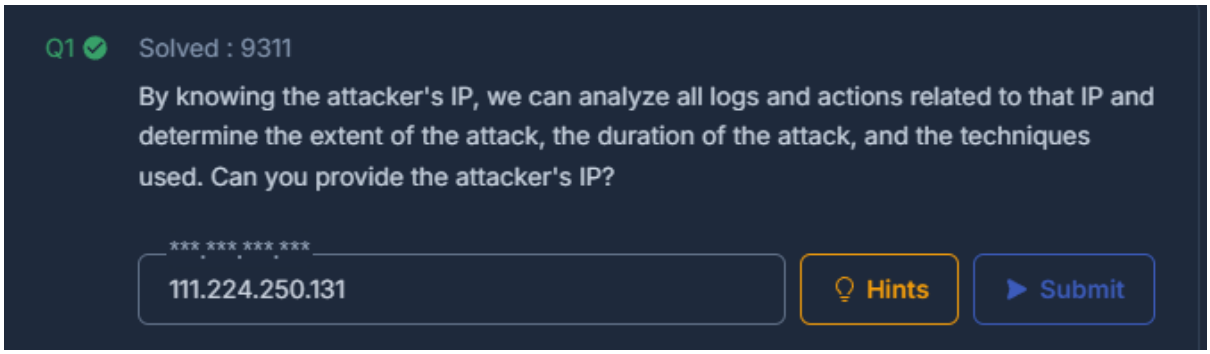
Google...

Matt Ball

Q1. By knowing the attacker's IP, we can analyse all logs and actions related to that IP and determine the extent of the attack, the duration of the attack, and the techniques used. Can you provide the attacker's IP?

I like to always start off with looking at statistics – conversations to see what's talking to what and the amounts of packets in transit, indicating the IP address trying to breach our server.

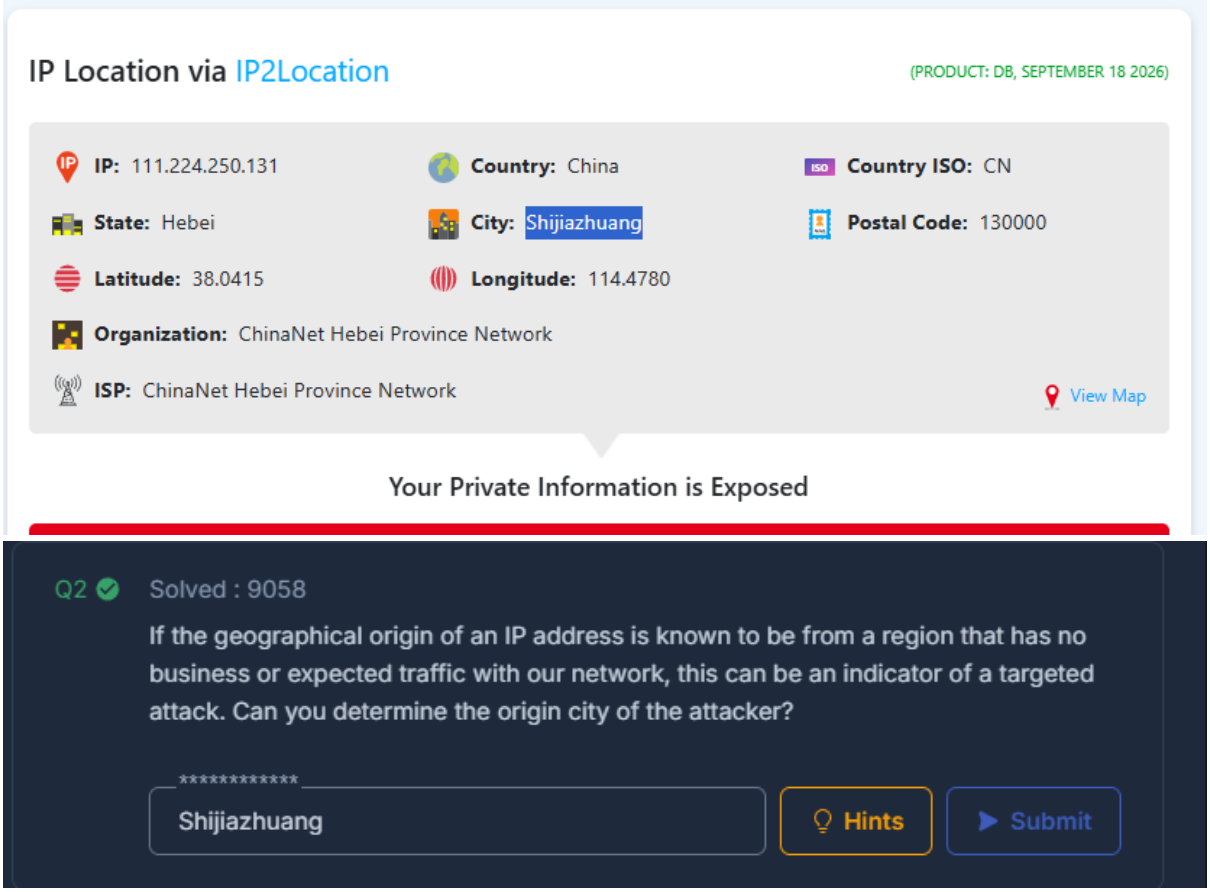


Matt Ball

Q2. If the geographical origin of an IP address is known to be from a region that has no business or expected traffic with our network, this can be an indicator of a targeted attack. Can you determine the origin city of the attacker?

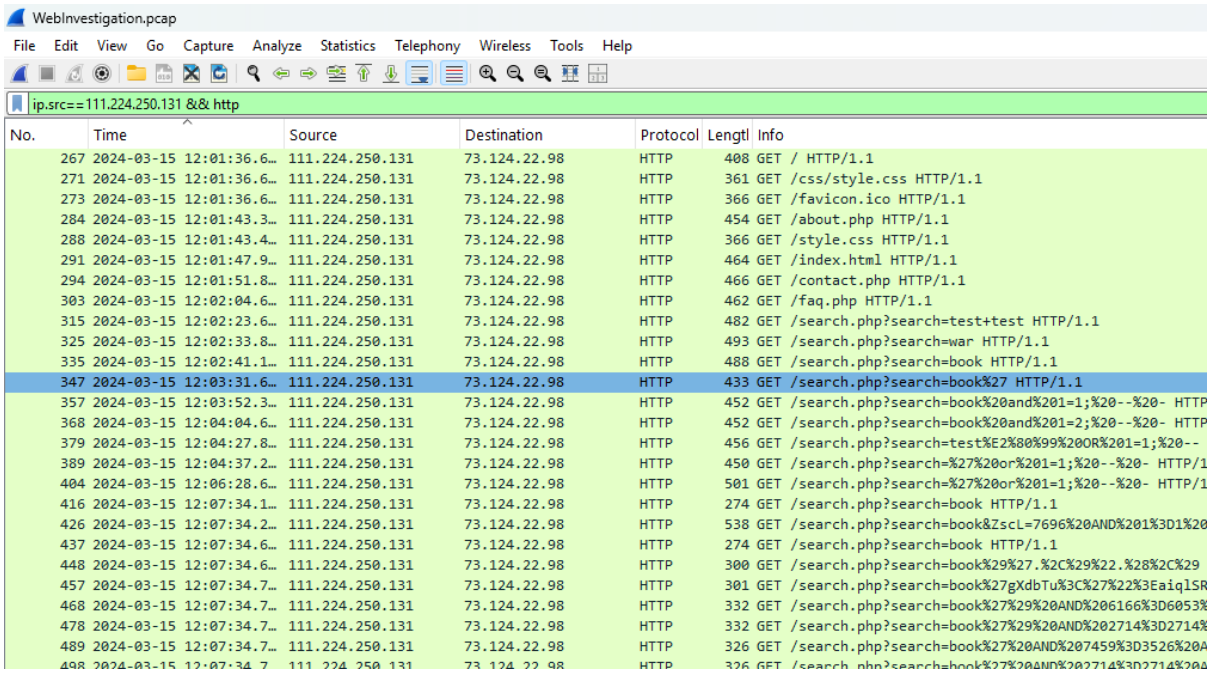
A simple IP check showing China immedietly raises suspicions...

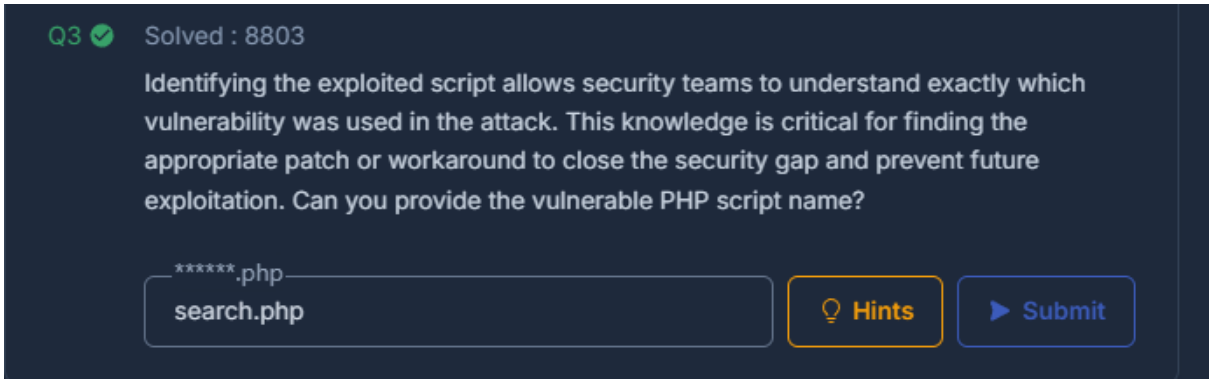


Matt Ball

Q3. Identifying the exploited script allows security teams to understand exactly which vulnerability was used in the attack. This knowledge is critical for finding the appropriate patch or workaround to close the security gap and prevent future exploitation. Can you provide the vulnerable PHP script name?

A quick search from the suspected IP, filtering for HTTP traffic shows a large amount of GET requests looking to exploit the search.php script



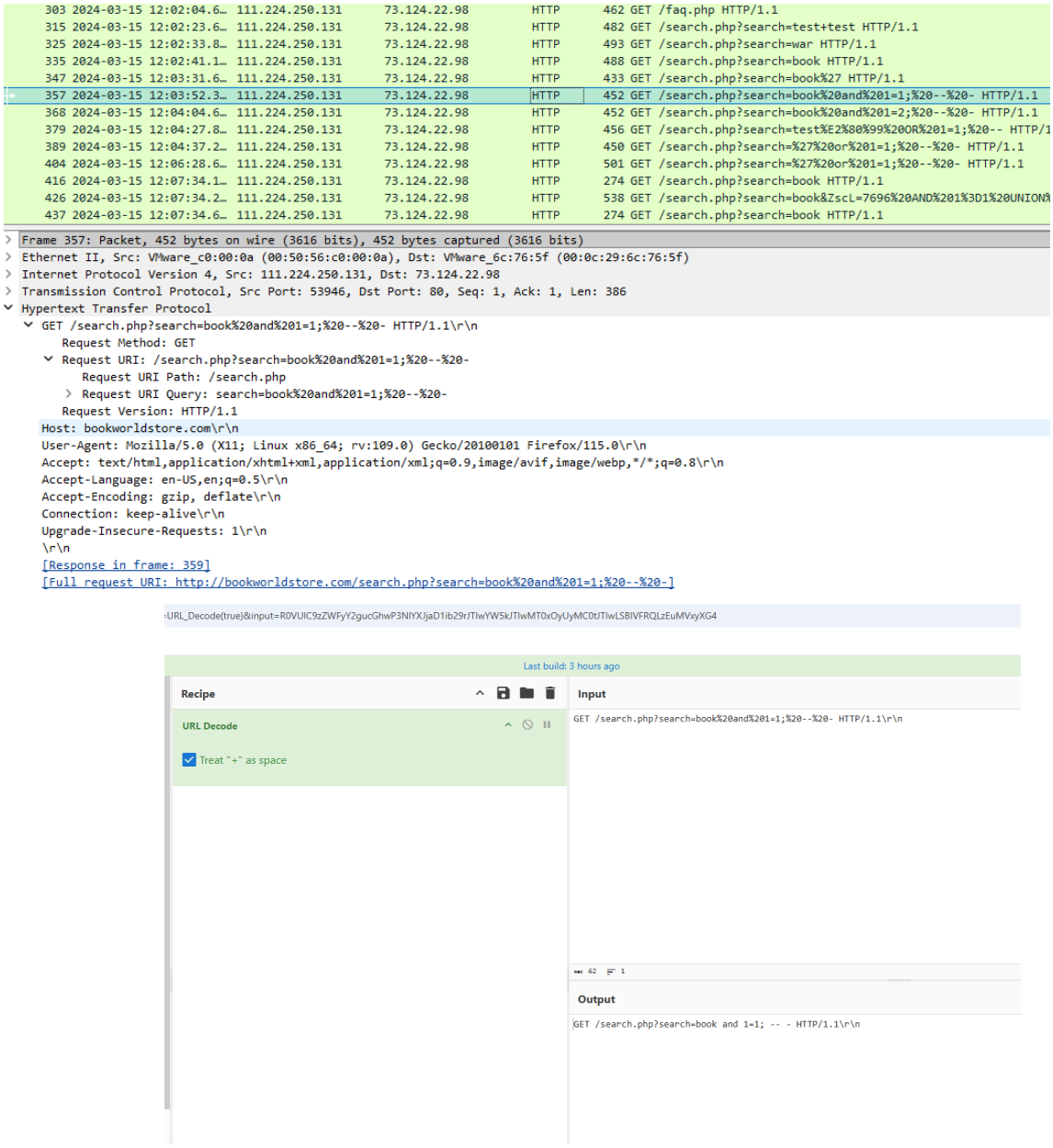
Matt Ball

Q4. Establishing the timeline of an attack, starting from the initial exploitation attempt, what is the complete request URI of the first SQLi attempt by the attacker?

Note: Decode the Value.

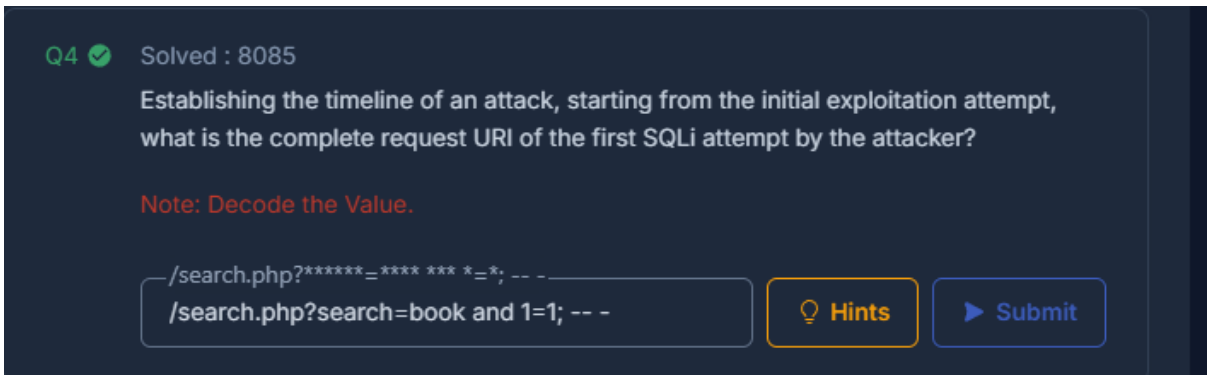
Now were getting to the nitty gritty..

The first indicator of SQLi from the GET requests sits here. We can tell that because the URI contains language such as 1=1, a classic sign of SQLi. We will de-obfuscate to make it clearer.







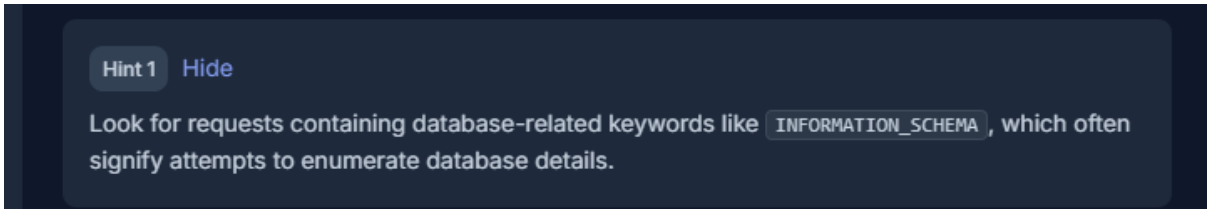


Matt Ball

Q5. Can you provide the complete request URI that was used to read the web server's available databases?

Note: Decode the Value.

Now this is where I started to struggle with lack of in depth SQLi knowledge.



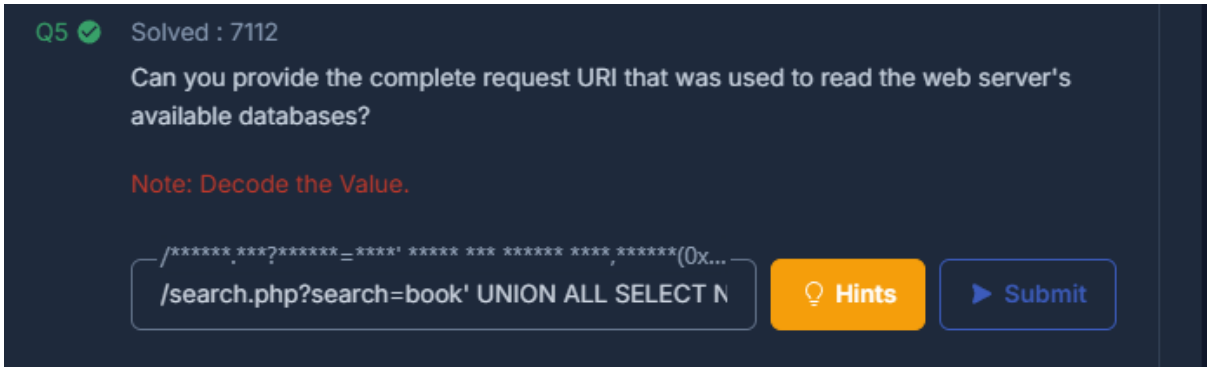

After a quick hint I use http contains “INFORMATION_SCHEMA” to see what I can see.

Also after a google I can see this is what is used to ‘allow you to find what tables are in your schema’ therefore it would be useful of the attacker to see if theres anything to dig into using this.




After digging through some results the bookworld.db stood out as the only databse in this search line.

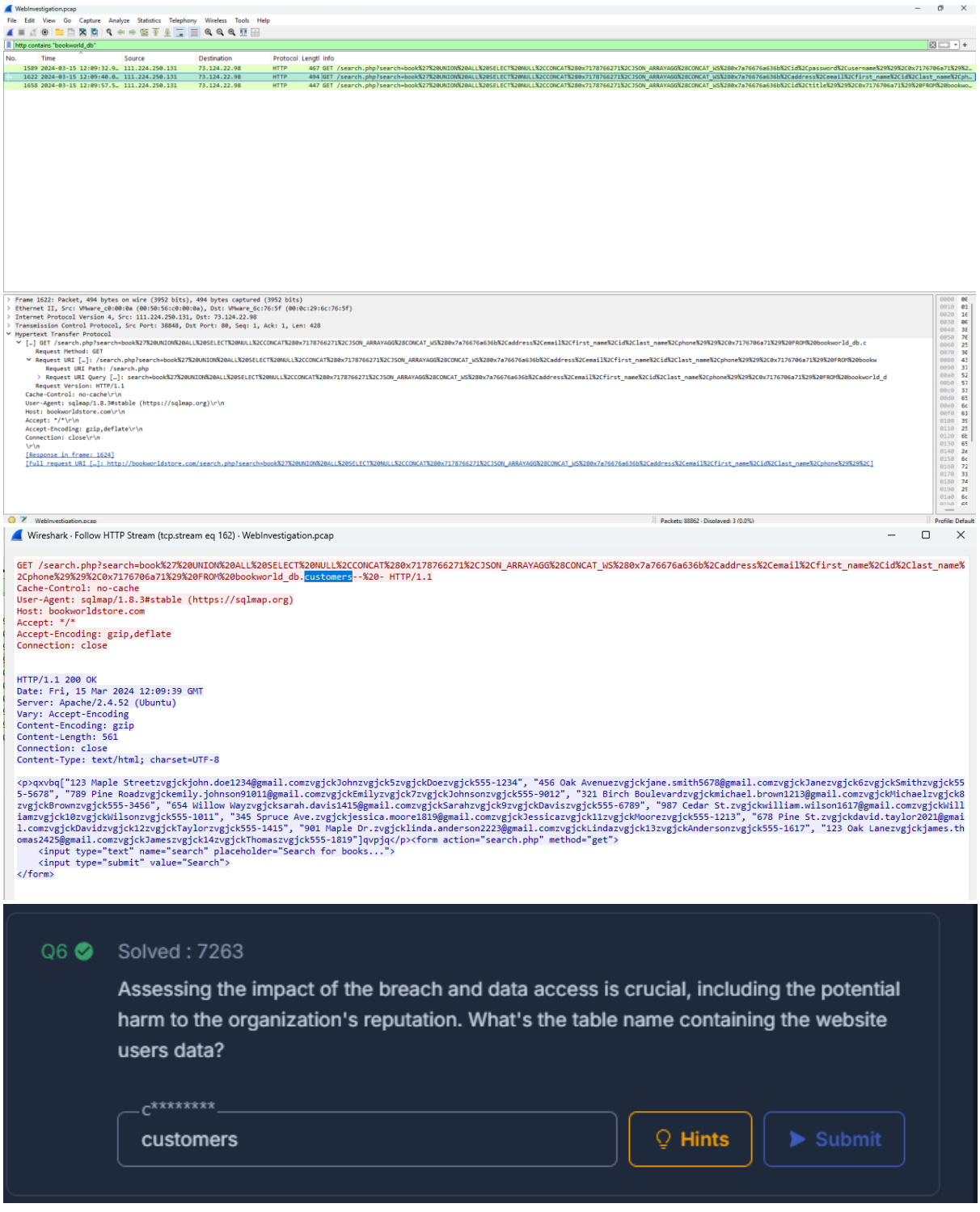
Lets clean it up with Cyber Chef and see if we’re correct.



Matt Ball

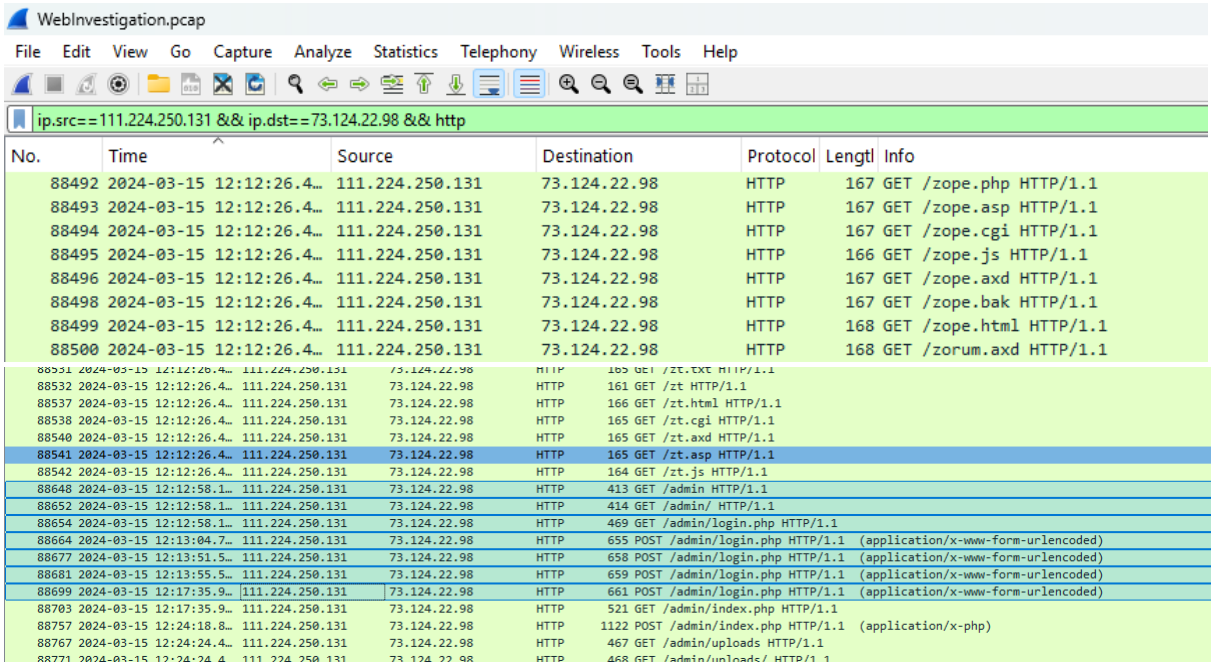
Q6. Assessing the impact of the breach and data access is crucial, including the potential harm to the organization's reputation. What's the table name containing the website users data?

Looking at the bookworld_db queries, only one was used that revealed user data. Another held some foreshadowing..

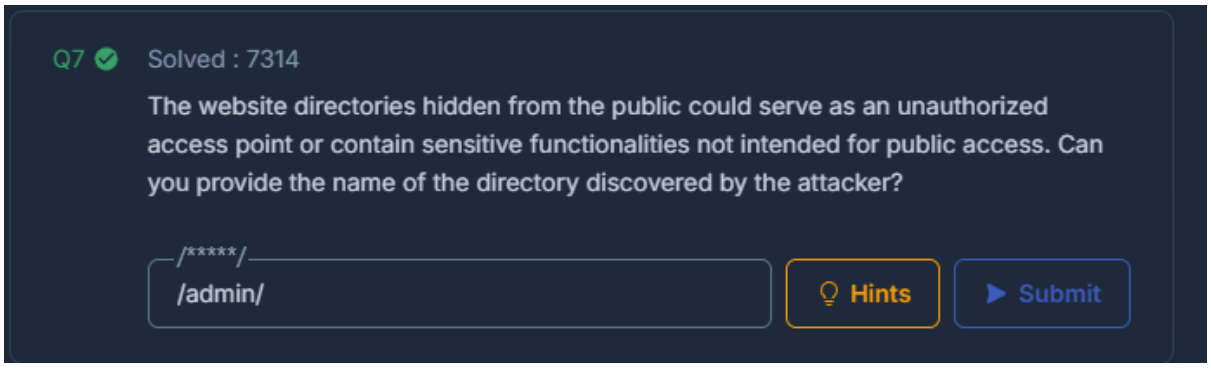


Q7. The website directories hidden from the public could serve as an unauthorized access point or contain sensitive functionalities not intended for public access. Can you provide the name of the directory discovered by the attacker?

I returned to the full request list from the sus IP to see what the full conversation looked like and eventually found some POST requests indicating that there might be a log in attempt or interacting with hidden functionalities from sus IP.



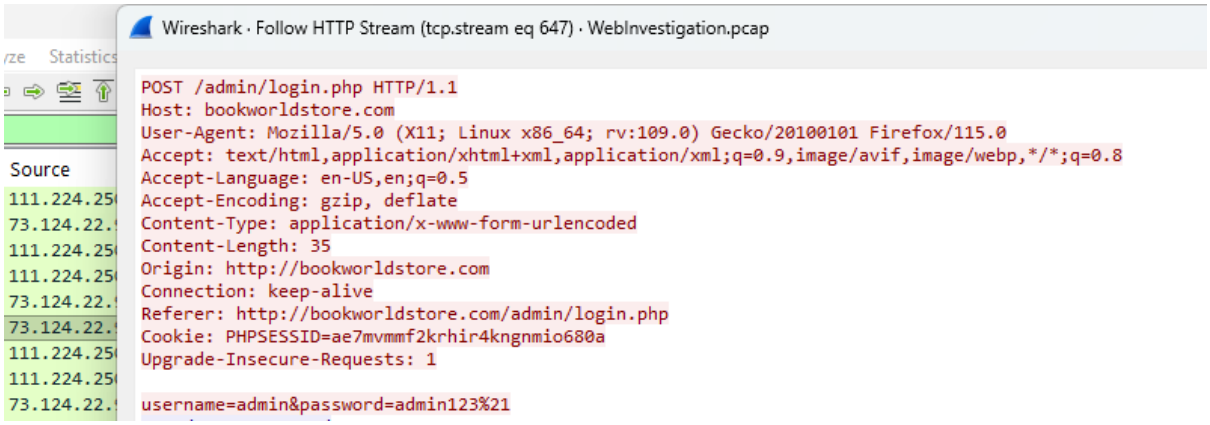

As you can see an admin directory would also be the place to get privelege escalation.



Matt Ball

Q8. Knowing which credentials were used allows us to determine the extent of account compromise. What are the credentials used by the attacker for logging in?

Going back to the POST requests I look at the last login attempt in the conversation before other interactions within the admin directory.

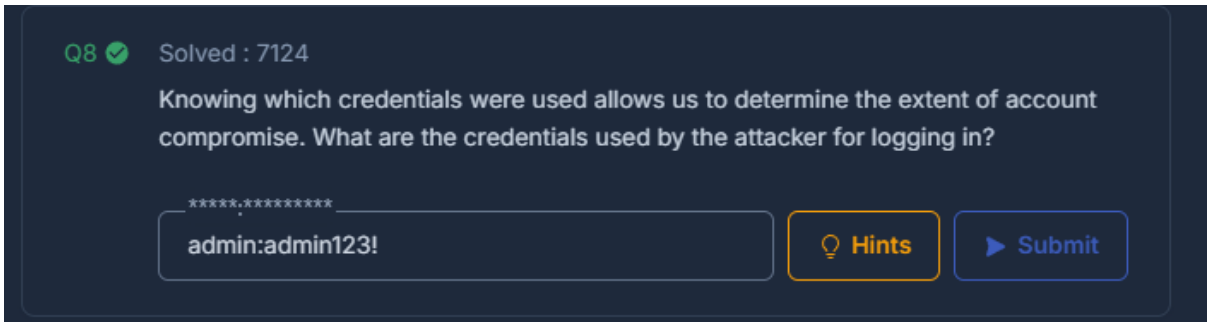



On a side note.. Through my travels on Q6 I found where the attacker found the credentials.




GET /search.php?search=book' UNION ALL SELECT NULL,CONCAT(0x7178766271,JSON_ARRAYAGG(CONCAT_WS(0x7a76676a636b,id,password,username)),0x7176706a71) FROM bookworld_db.`admin`--

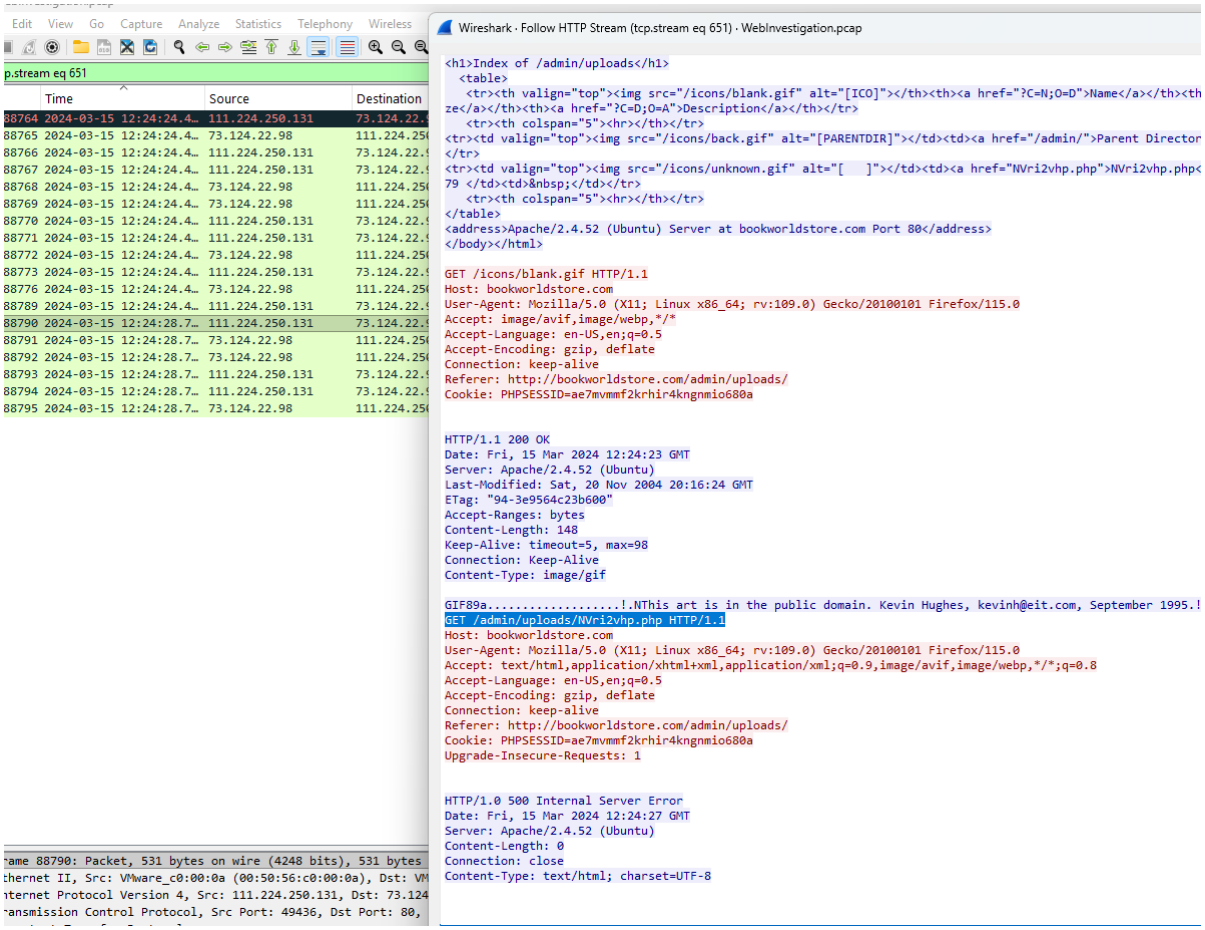
That would do the trick.

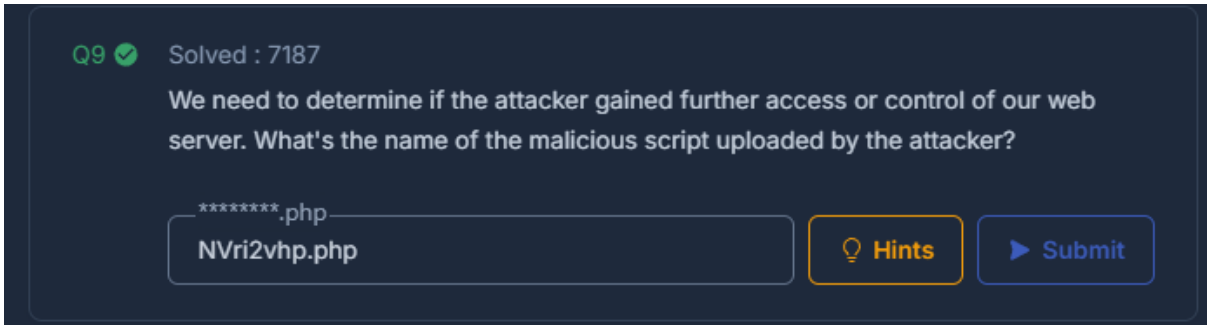


Matt Ball

Q9. We need to determine if the attacker gained further access or control of our web server. What's the name of the malicious script uploaded by the attacker?

Following the conversation after the log in we can see that the attacker uploaded a script.



Matt Ball

Findings:

It was very interesting to see SQLi unfolding and creating a picture of initial start to malicious uploading of scripts.

I learnt a lot more about how SQLi works and certain things to look out for such as INFORMATION_SCHEMA. I also appreciated how Cyber Chef can be used to make text a bit more human readable.

Some findings along the way would be don't store admin username and password on the database and certainly not in plain text...

Another thing to consider would be input handling from the server and that would be a good thing to look at for me going forward.